

Dynamic Application Security Testing (DAST)

Learning objectives

- **Identify how DAST helps identify vulnerabilities**
- **Explain the differences between black-box and gray-box testing approaches**
- **Explain why DAST is useful in modern security pipelines**
- **Describe how DAST supports secure applications**

What is DAST?

- **Mimics real-world attacks**
- **Tests applications while they are running**
- **Focuses on runtime vulnerabilities**
- **Does not require access to source code**

How DAST works

- Deploy the web app in a test environment
- Run a DAST tool like OWASP ZAP
- It interacts with the login form using automated suspicious inputs
- It enters inputs like:
 admin' OR '1'='1
 <script>alert('xss')</script>
- The app responds with unexpected behaviour or error messages
- DAST flags possible injection and XSS vulnerabilities
- You receive a report and fix the issues before deployment

DAST vs SAST: what's the difference?

Feature	DAST (Dynamic)	SAST (Static)
Application state	Running	Source code only
Access to code	Not required	Required
Testing focus	Behaviour during execution	Code logic and structure
User perspective	External (attacker view)	Internal (developer view)

Black-box testing

- **The tester has no access to code or system internals**
- **The tester simulates an outsider with no prior knowledge**
- **It tests the system purely through its interfaces**
- **It is ideal for mimicking external attacks**

Gray-box testing

- **The tester has partial knowledge of the system**
- **They may know architecture, credentials or user roles**
- **It combines targeted internal understanding with external testing without the need to fully access the source code**
- **It balances realism and efficiency**

Why use DAST?

- **Reveals real-world vulnerabilities**
- **Works with any language or tech stack**
- **Does not need code access**
- **Helps meet compliance standards**
- **Suits black-box and gray-box approaches**

The challenges of using DAST

- **May miss internal or logic-based bugs**
- **Needs a working test or staging app**
- **Can generate false positives or incomplete test coverage**

DAST tools you should know

- **OWASP ZAP**
- **Burp Suite**
- **Acunetix**
- **Netsparker**
- **IBM AppScan**
- **Qualys Web Application Scanner**

Summary

- **DAST tests live applications, mimics real attacks**
- **Black-box = external attacker's view**
- **Gray-box = partial system insight**
- **DAST is effective for runtime flaws**

Reflection

- **In what situations would gray-box testing give better results than black-box testing?**

Next

- **What cryptography is**
- **The basics of encryption, decryption and keys**
- **How cryptography protects things**